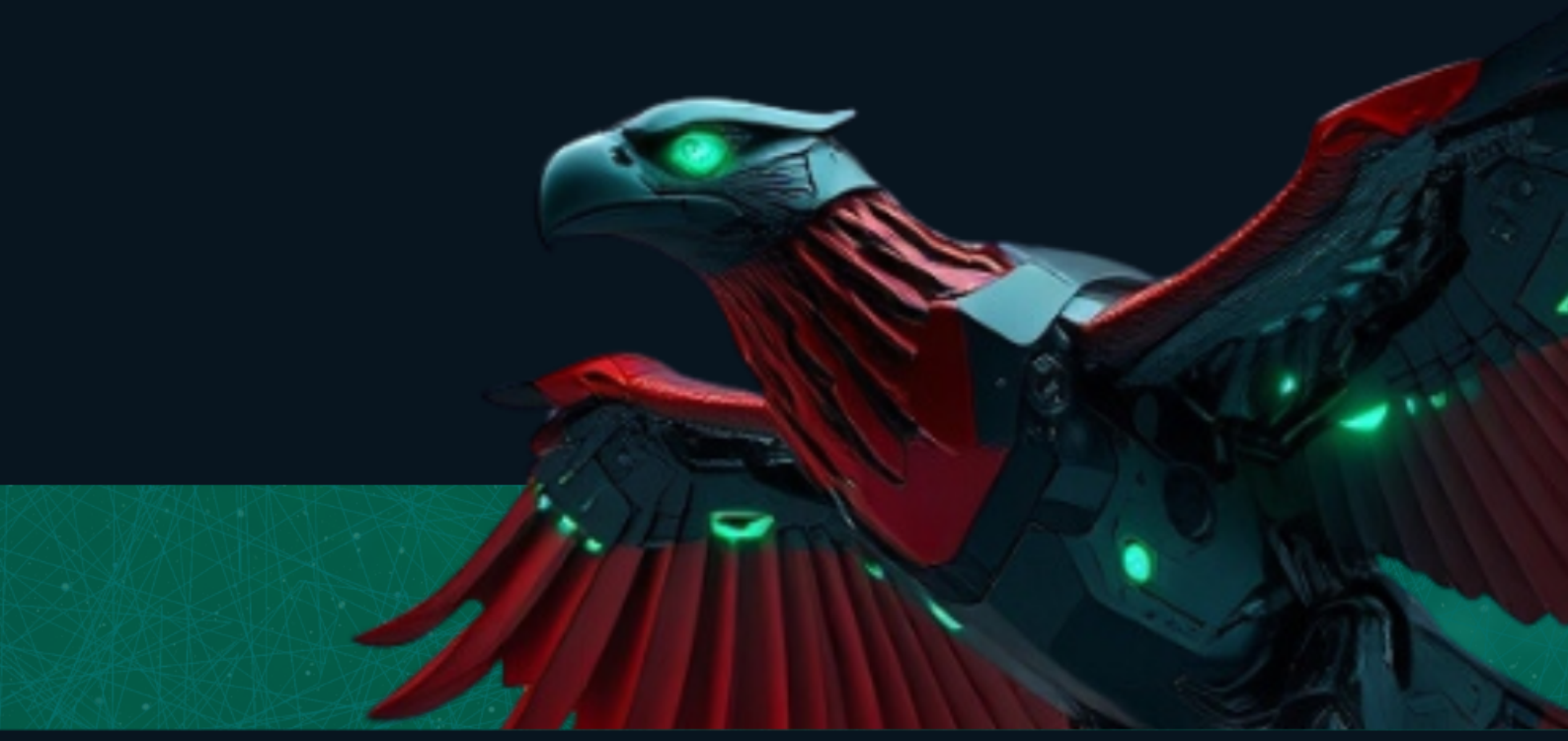
SOCBYTE
ALL BYTES SECURED

INTEL REPORT



Report Details

Title	Threat Hunt Blind Spider
Sub Title	Persitsent adversary who rapidly Deploys
Status	Open
Type	Alert
Severity	Medium
Source	Multiple Sources
Created At	Aug 05, 2026, 09:11 PM

Threat Hunt Blind Spider

Persitsent adversary who rapidly Deploys

Type: ALERT • Source: Multiple Sources • Created At: Aug 05, 2026, 09:11 PM

Analysis Summary

On August 8th, 2026 at 8:15 PM, Cythority's vSOC conducted a threat hunt focused on Blind Spider covering activity within the past 30 days.

Blind Spider is a regional threat actor group active since at least 2018. Primarily associated with operations in South America, the group is best known for its persistent targeting of government institutions, financial organizations, energy sectors, and critical infrastructure, with a heavy operational focus on Colombia and neighboring Latin American countries such as Ecuador and Chile.

While some threat intelligence providers categorize Blind Spider as a cyber-espionage unit, its operations heavily align with financially motivated eCrime. The group regularly impersonates official government entities, such as Colombia's tax and customs agency (DIAN), as well as major regional banking institutions like Bancolombia and BBVA to lure victims into revealing credentials or compromising internal networks.

Technically, Blind Spider is known for rapid deployment and operational efficiency rather than complex infrastructure concealment. They rely heavily on spear-phishing campaigns distributing malicious email attachments or links hosting obfuscated VBScript, PowerShell payloads, and malicious .url files. Their attack chains frequently leverage open-source or commercial Remote Access Trojans (RATs) such as Remcos and Imminent Monitor, alongside dynamic DNS services like DuckDNS and strict geolocation filtering to restrict payload execution exclusively to victims within their targeted geographic regions.

During this hunt, a total of 20 Indicators of Compromise (IOCs) were identified, including domains, URLs, IP addresses, email addresses, filenames, and file hash values. These indicators were aggregated from CrowdStrike, internal telemetry, and additional intelligence sources referenced in this report. All identified

IOCs were enriched using OSINT and threat intelligence platforms to validate their reputation. Analysis confirmed that the indicators are associated with malicious activity.

A CQL Advanced Event Search was conducted across the environment to identify any evidence of activity related to these indicators. No matches or suspicious activity were observed, confirming no current or historical presence within the environment. As a preventative measure, the validated malicious IOCs have been added to the IOC Management Block List to mitigate potential future exposure. This proactive control strengthens the security posture and reduces the attack surface. Based on the investigation and analysis performed, no impact to the environment has been identified and no further action is required at this time.

Targeted Industries:

Entertainment, Government, Technology, Retail, Automotive, Aviation, Real Estate, Transportation, Manufacturing, Financial Services, Energy

Targeted Countries:

Chile, Colombia, Ecuador

Community Identifiers:

TAG-144, APT-C-36, Blind Eagle

Affected Product

- Windows OS (All Versions): Targeted via malicious .url files, modified Windows shortcuts, and executables. Attacks frequently target Windows NTLM/NTLMv2 authentication mechanisms and WebDAV protocol handling to harvest credentials or notify attackers of file interaction.
- Microsoft Office (Word/Excel): Malicious document attachments (.docm, .xlsm) containing VBA macros designed to drop initial payloads.
- Google Chrome, Microsoft Edge, & Mozilla Firefox: Targeted by secondary RAT payloads (AsyncRAT, njRAT, BitRAT) to harvest stored login credentials, auto-fill data, and active session cookies.
- Outlook & Local Mail Clients: Targeted for credential extraction and to hijack local email sessions for secondary phishing propagation.
- Colombian / South American Banking Portals: Custom banking trojans (e.g., modified QuasarRAT variants) target local online banking portals, financial institution clients, and payment gateways.
- Google Drive, Dropbox, GitHub, & Bitbucket: Legitimate user accounts and cloud storage instances are targeted for compromise to host and distribute secondary payloads.
- VNC & RDP Clients: Remote access interfaces targeted by RATs to grant attackers interactive access to compromise host machines.

Impact

- Financial Loss & Fraud: Because the group operates as an eCrime/financially motivated threat actor, compromise often leads to direct theft of funds, fraudulent wire transfers, and stolen banking or payment credentials.
- Credential & Data Theft: Deploying remote access trojans (RATs)—such as AsyncRAT, njRAT, and DCRat—allows them to log keystrokes, capture login credentials, exfiltrate sensitive files, and harvest NTLM hashes.
- Espionage & Loss of Intellectual Property: Beyond financial cybercrime, Blind Spider conducts targeted cyberespionage, risking the exposure of proprietary business operational data, trade secrets, and confidential communications.
- Supply Chain & Third-Party Risks: Organizations can be leveraged as entry points to target interconnected business partners, suppliers, or parent/subsidiary entities across the region.
- Operational Disruption: Infiltration via living-off-the-land techniques and secondary payloads (including potential ransomware execution) can lead to system downtime, degraded network performance, and disrupted daily operations.
- Regulatory Compliance & Legal Fallout: Data breaches involving customer or government data can result in compliance violations, legal litigation, and regulatory fines.
-

Reputational Damage: Incident publicity damages partner trust, customer confidence, and overall brand standing in targeted markets.

Indicators of Compromise (IOCs)

MD5 Hashes

- 8a3740e184b1083e17ca4c3cfe134d6c
- 0b0ab09f0ef9360b9e93faba16898f3d
- 61479d2fa680ace5f8313ea74371ea1a
- 746ef96bb43b67836cec5753d3739477
- 00fd2ecbaf20bf168769727830329398

SHA256 Hashes

- A908d80c6e2ee75c96529b9132617ac2c946ddb5a1bc6ca29908d69c33977b11
- 4083fa20a377f36690c1b6d3a6a51d0cc7c3afba4af57a313387595efff38c12
- 646fd36164b50b21818c81ee91436092b297ff45863d1653792743b3a475cc0a
- 4beb1fb31089bfda9b71e20b2ad5e9f5367bc72b137455515d773b0235a6c635
- 6cb4bad07de857d8c7b8a90c13efc5edf7aadf426c2a4e59189e2a7a42cb5953

IP

- 91[.]92[.]242[.]165
- 45[.]83[.]31[.]50
- 45[.]83[.]31[.]11
- 172[.]94[.]9[.]23
- 193[.]26[.]115[.]183

DOMAIN

- mastermrc2.kozow[.]com
- powernex2026.kozow[.]com
- envio01.gleeze[.]com
- ansiratenvio.dynuddns[.]net
- tiendasglobal.duckdns[.]org

Remediation

• Configure Secure Email Gateways (SEGs) to inspect inbound archives and flag or block messages containing .url, .vbe, .vbs, or shortcut (.lnk) attachments.

• Restrict or block inbound emails containing links to public cloud platforms (Google Drive, Bitbucket, GitHub) or Dynamic DNS services (.duckdns.org, no-ip.com) when not required for business operations.

• Implement AI/behavioral email analysis to detect spoofed internal accounts and spear-phishing lures.

• Prioritize security patches for Windows authentication and file handling mechanisms, particularly NTLMv2 and WebDAV disclosure vulnerabilities (e.g., CVE-2024-43451).

• Disable or restrict outbound SMB (TCP port 445) and WebDAV traffic at the perimeter firewall to prevent forced NTLM credential harvesting over the internet.

• Enforce PowerShell Constrained Language Mode (CLM) and enable Script Block Logging (Event ID 4104) to limit fileless script execution.

• Block macro execution by default via Microsoft Office Group Policy settings for files downloaded from the web.

• Disable host-level execution of VBScript (wscript.exe / cscript.exe) or associate .vbs and .vbe extensions with Notepad instead of script interpreters.

• Deploy behavioral EDR rules to detect process hollowing, DLL side-loading, and unnatural parent-child process relationships (e.g., cmd.exe, powershell.exe, or mshta.exe spawned directly from Office products or web browsers).

• Monitor persistence mechanisms, including changes to Windows Registry startup keys (Run / RunOnce), new Scheduled Tasks, and modifications to startup folders.

• Inspect outbound network traffic for non-standard ports, persistent encrypted channels, and remote access trojan (RAT) signature traffic (AsyncRAT, Remcos, DCRat).

• Enforce strict web filtering policies that restrict unauthorized cloud-storage downloads and block dynamic DNS domains used for dynamic Command-and-Control (C2) hosting.

• Enforce Multi-Factor Authentication (MFA) across all external-facing portals, webmail, and VPN connections to mitigate stolen session cookie and credential attacks.